

# Deep Dive — Sectors, Data Protection, Standards, and IP

Part 14 —  AI Compliance · 14-ai-compliance/notes/02-sectors-data-protection-and-standards.md

The regulatory landscape from notes/01 tells you which *horizontal* AI-specific rules apply. This file covers the equally important *vertical* question: what does AI have to fit into, because a sector was already regulated before AI showed up? Then it covers the two cross-cutting bodies of law every AI system touches (data protection, IP) and the certification standards that turn "we're compliant" into something an outside party can verify.

## 1. Healthcare: HIPAA plus an evolving FDA framework

HIPAA doesn't mention AI. It governs Protected Health Information (PHI) regardless of what processes it — an LLM summarizing clinical notes is a "workforce member's tool" from a compliance standpoint, and every existing HIPAA obligation (minimum necessary use, Business Associate Agreements with any vendor touching PHI, breach notification, access controls) applies unchanged. The practical trap: a clinician pasting a patient note into a general-purpose chatbot without a BAA in place is a HIPAA violation regardless of how good the model's output is.

Where AI gets *specific* rules is FDA regulation of AI/ML as (part of) a **medical device (SaMD)**. As verified: the FDA's structural challenge with AI/ML is that these models can change after clearance — retraining shifts behavior in ways the traditional "clear it once, it's frozen" device model can't accommodate. The FDA's answer, now finalized, is the **Predetermined Change Control Plan (PCCP)**: a manufacturer submits, as part of the original marketing application, the specific future modifications it intends to make, the validation methodology for those changes, and the performance boundaries within which changes can happen *without* a new submission. The FDA's final PCCP guidance took effect **August 2025**; draft guidance on the AI-enabled device Total Product Life Cycle sits alongside it. Concretely: an AI diagnostic model that improves via periodic retraining on new imaging data needs a PCCP describing exactly how that retraining will be validated, or every retrain risks triggering a new submission. Verify current FDA guidance status before relying on specifics — this is one of the more actively-drafted corners of US AI regulation.

## 2. Financial services: model risk management is the existing baseline

Banks did not wait for "AI regulation" — they already had **model risk management (MRM)** expectations covering any quantitative method that turns inputs into decisions, AI/ML included. The foundational US guidance was the Federal Reserve/OCC/FDIC's **SR 11-7** (2011): validate conceptual soundness, monitor ongoing performance, and analyze outcomes, with rigor scaling to a model's materiality. **Verified: in April 2026** the same three agencies issued **SR 26-2**, replacing SR 11-7 with guidance explicitly modernized for the intervening 15 years of modeling practice — including, implicitly, LLM-based and ML-heavy models that SR

11-7's drafters never anticipated. If you work in or with a US bank, confirm which guidance your counterparty's examiners are currently applying; a lot of internal documentation still cites SR 11-7 by name.

The second layer is **fair lending law** — the Equal Credit Opportunity Act (ECOA) and Regulation B — applied to AI credit models. The rule that survives any framework change: a credit decision must be explainable enough to produce **adverse action notices with specific, accurate reasons for denial**. A black-box model that can't produce a specific reason ("insufficient credit history" vs. an opaque score) is a fair-lending problem regardless of its AUC. This is the sharpest real-world collision between "our model is more accurate" and "our model must be explainable to a rejected applicant," and it's why credit-scoring teams reach for inherently interpretable models or rigorous post-hoc explanation methods well before an AI-specific law forces the issue.

### 3. Employment: AI hiring tools inherit anti-discrimination law, plus new audit mandates

---

Federal disparate-impact theory under Title VII already applies to any hiring tool, algorithmic or not — a tool that screens out a protected group at a materially different rate is presumptively problematic even with no discriminatory intent. What's new is procedural: cities and states are layering **mandatory bias audits** on top. The reference example, **NYC Local Law 144** (effective July 2023): employers using an "Automated Employment Decision Tool" for NYC-based roles must have it audited annually by an independent auditor for disparate impact, publish a summary of the audit, and notify candidates the tool is in use. **Verified as of the last check:** LL144 remains in active enforcement by NYC's Department of Consumer and Worker Protection, with several hundred audits filed since 2024 — but a December 2025 city Comptroller review found enforcement inconsistent, and penalty actions have been sporadic rather than systematic. Practical lesson: "a law with real teeth on paper" and "a law that is actively, consistently enforced" are different risk levels, and you should track both — the second changes faster than the first.

### 4. Data protection law, applied specifically to AI

---

GDPR predates the generative-AI era but reaches deep into how you build and run AI systems in or serving the EU (and, via extraterritorial scope, often beyond it).

- **Lawful basis for training data.** Training on personal data needs a lawful basis under Article 6 — usually "legitimate interest," which requires a documented balancing test against data-subject rights. Web scraping at pretraining scale did this implicitly at best; regulators (several EU DPAs, and the Italian Garante's earlier ChatGPT action) have pushed back specifically on this point. If you fine-tune on your own users' data, you need a basis for *that* processing too, separate from whatever basis covers the base model.
- **The "right to explanation" debate.** GDPR does not contain the words "right to explanation." Article 22 gives a right *not* to be subject to a decision based **solely** on automated processing that has legal or similarly significant effects, plus (with Articles 13–15) a right to "meaningful information about the logic involved." Courts and regulators disagree on how much that adds up to in practice, and whether it's owed before or after the decision. Design conclusion, independent of how that debate resolves: keep a human meaningfully in the loop for legal/significant-effect decisions (not a rubber stamp — see Module 12's

human-oversight material [12-ai-governance]), and be able to state, in plain language, what inputs drove a specific output.

- **Data minimization vs. large-scale training.** GDPR's minimization principle ("no more data than necessary") sits in structural tension with the "more data, better model" logic of pretraining. There's no clean resolution here — it's an active area of regulatory and academic disagreement, not a solved problem you can cite a settled answer for.
- **Automated decision-making restrictions.** Beyond Article 22's narrow "solely automated" trigger, GDPR's general transparency and fairness principles apply to any profiling, automated or human-assisted.

**RAG and agent systems inherit all of this in full**, and teams routinely underestimate this. A RAG pipeline that retrieves and surfaces personal data from a document store is processing personal data under GDPR the moment it touches that data — the fact that an LLM sits in the loop changes nothing about the legal analysis. Concretely: a retrieved chunk containing an employee's health note, quoted back in a chatbot answer, is a GDPR processing event (and possibly special-category data under Article 9) with its own lawful basis and minimization requirements, independent of the underlying document's original purpose. See Module 08 [08-rag] for the retrieval architecture and Module 13's PII-handling controls [13-ai-security] for the technical mitigations (redaction, access-scoped retrieval, output filtering) — this module tells you *why* those controls are a legal requirement, not just good hygiene.

## 5. Standards and certification: making compliance verifiable to a third party

---

### ISO/IEC 42001 — the certifiable AI management system standard

Published December 2023, ISO/IEC 42001 is structured like ISO 27001 (information security) and ISO 9001 (quality) — deliberately, so organizations already certified to those can extend the same management-system muscle to AI rather than building a parallel program. **Verified structure:** Clauses 4–10 (Context, Leadership, Planning, Support, Operation, Performance Evaluation, Improvement) plus **Annex A**, which defines roughly three dozen controls across areas like AI policy, resourcing, impact assessment, and lifecycle/data governance. Certification is via an accredited third-party auditor, typically valid three years with periodic surveillance audits. It certifies that you **run a disciplined process** for managing AI risk — it does not certify that any specific model is safe, accurate, or legally compliant. Treat it as "we have a real AI governance program," which is a strong but different claim than "our resume-screener is EU-AI-Act-compliant."

### SOC 2 for an AI feature

SOC 2 isn't AI-specific, but auditors have converged on what they actually ask about an AI feature inside a broader SOC 2 audit (typically under the Security and, if claimed, Confidentiality/Privacy trust-service criteria): Is there access control over model endpoints and training data? Is there a change-management process for model/prompt updates (mirroring code-deployment controls)? Is there logging of AI-driven decisions sufficient to reconstruct what happened? Is there a vendor-management record for any third-party model API? Is there an incident-response plan covering AI-specific failure modes (data leakage via completions, prompt injection)? None of this is new SOC 2 territory conceptually — it's existing trust- service criteria applied to a system that happens to include a model.

## 6. Intellectual property and copyright — genuinely unsettled, don't overstate it

---

**Training-data copyright status.** As of the last verification, this is *not* settled US law, and any claim that it is should be treated skeptically. Two data points worth knowing, both true as of the last check and both narrower than headlines suggest:

- **Bartz v. Anthropic:** Judge Alsup's June 2025 summary-judgment ruling held that training on *legitimately acquired* books was fair use, but explicitly did **not** extend that to books acquired via piracy (the ~500,000-book LibGen/PiLiMi corpus) — that piracy claim proceeded, and Anthropic settled it for **\$1.5 billion** (final court approval **July 2026**), the largest copyright settlement on record. Read this correctly: the settlement resolved a piracy claim, and the fair-use-for-legally-acquired-training-data holding, while a real precedent, is one district court's ruling, not a Supreme Court or circuit-wide rule.
- **NYT v. OpenAI/Microsoft:** filed December 2023, still actively litigated as of September 2026 (dispositive motions being argued, no trial verdict yet), with the US DOJ notably filing a brief in the case supporting OpenAI's position that training on copyrighted text is not itself infringement — the government's first stated position on this question. **This case is unresolved.** Do not cite an outcome; cite that it's pending and consequential.

**Output ownership and copyrightability.** Separately murky: US Copyright Office guidance has leaned toward denying copyright protection to outputs with no meaningful human authorship, while allowing protection for the human-authored parts of a human/AI-collaborative work. This is evolving guidance, not settled doctrine — verify current Copyright Office position before treating any specific output as protectable or not.

**Open-weights licensing is not one thing.** "Open" describes weight availability, not legal freedom to use. Compare, at a level of generality that should prompt you to always read the actual license text: Meta's Llama license carries a commercial-use restriction above a monthly-active-user threshold and an acceptable-use policy; Mistral's Apache-2.0-licensed models carry essentially no use restrictions; some research-only releases (various RAIL-licensed models) prohibit commercial use entirely, or specific downstream uses (law enforcement, health decisions). None of this is about who trained the model well — it's a contract question, and getting it wrong means a compliance problem with no relationship to model quality. See Module 11's open-vs-proprietary discussion [11-llm-models] for the technical/business trade-offs; this module's point is narrower — **read the license, every time, before commercial deployment**, because "open-weights" is doing a lot less legal work than it sounds like it does.

## 7. Forward links

| Idea here                                                     | Where it returns                                                                                                                                                          |
|---------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Human-in-the-loop for Article 22 / adverse-action decisions   | Module 12 [12-ai-governance]                                                                                                                                              |
| PII/PHI redaction and access-scoped retrieval                 | Module 13 [13-ai-security], Module 08 [08-rag]                                                                                                                            |
| Model selection given license terms                           | Module 11 [11-llm-models]                                                                                                                                                 |
| Turning ISO 42001 / SOC 2 evidence into a single artifact set | notes/03 [14-ai-compliance/notes/03-building-a-compliance-program.md], code/compliance_documentation_mapper.py [14-ai-compliance/code/compliance_documentation_mapper.py] |